Confidentia
l

Module 9: Spring Security Basics (Day 2)

A BPI Training Program

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Confidentia
l

Day 3 — Security Context, Exception Handling and Best Practices

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is strictly prohibited.

THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Learning Objectives:

1. **Understand the Security Context**
2. **Handle Security Exceptions**
3. **Apply best practices**

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is strictly prohibited.
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Key Takeaways from Day 2 Session

- Authorization (Purpose, Roles and Where roles come from)
- URL-Based authorization and Method-level authorization
- @PreAuthorize, @Secured
- Customizing UserDetailsService and DaoAuthenticationProvider
- Database Authentication and Authorization

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Security Context: What is it?

- **Purpose:** Stores the **currently authenticated user** and authorities
- **Stored in:** `SecurityContextHolder` (per thread by default)
- **Contains an Authentication object:**
  - `principal` → user identity (username or `UserDetails`)
  - `authorities` → roles/permissions
  - `credentials` → usually cleared after authentication
  - `authenticated` → boolean flag

Flow:

SecurityContextHolder → SecurityContext → Authentication → Principal + Authorities

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Accessing Current User (Option 1: SecurityContextHolder)

```
Authentication auth = SecurityContextHolder.getContext().getAuthentication();

if (auth != null && auth.isAuthenticated()) {
      String username = auth.getName();
      Object principal = auth.getPrincipal();
      Collection<? extends GrantedAuthority> roles = auth.getAuthorities();
}
```

- `SecurityContextHolder` stores the **SecurityContext** for the current thread.
- `SecurityContext` contains the **Authentication object**, representing the current user.
- `auth.getPrincipal()` usually returns a `UserDetails` object, or a username string if not using a custom user.
- `auth.getAuthorities()` gives the **roles/permissions** for the user.

Pros: Works anywhere in your app

Important: Always check `auth != null` and `auth.isAuthenticated()` to avoid null pointers or anonymous users.

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is strictly prohibited.

THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Accessing Current User (Option 2 & 3)

Option 2 — `@AuthenticationPrincipal` (Controller Injection):

```
@GetMapping("/profile")
public String profile(@AuthenticationPrincipal UserDetails user) {
      return "Hello, " + user.getUsername();
}
```

Option 3 — `Principal` (Simple Username):

```
@GetMapping("/hello")
public String hello(Principal principal) {
      return "Hello, " + principal.getName();
}
```

Use Cases:

Option 2 → returning **user profile info** including roles
Option 3 → simple greeting or logging username

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Accessing Current User (Comparison Table)

Feature	`SecurityContextHolder`	`@AuthenticationPrincipal`	`Principal`
Scope	Anywhere (services/controllers)	Controllers	Controllers
Access	Full Authentication	UserDetails	Username only
Roles	Available	Available	Not directly
Complexity	Slightly more code	Cleaner in controllers	Very simple

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Confidentia
l

Exception Handling in Spring Security

Purpose:

- Handle security failures gracefully
- Provide meaningful responses to clients

Two main types of exceptions:

Exception	Trigger	Default HTTP Response
`AuthenticationException`	Unauthenticated access	401 Unauthorized
`AccessDeniedException`	Authenticated but unauthorized	403 Forbidden

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Confidentia
l

AccessDeniedException

- Triggered when an **authenticated user tries to access a forbidden resource**.
- **Examples:**
  - User with ROLE_USER accessing `/admin/**`
  - Method-level security: `@PreAuthorize("hasRole('ADMIN')")`

Default Behavior:

- Returns 403 Forbidden
- Browser: shows a default error page
- REST API: default response is HTML, not JSON

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Customizing Authentication Failure Response

Use `AuthenticationEntryPoint` for REST APIs

```
@Component
public class CustomAuthEntryPoint implements AuthenticationEntryPoint {
      @Override
      public void commence(HttpServletRequest req, HttpServletResponse res,
                           AuthenticationException ex) throws IOException {
            res.setStatus(HttpServletResponse.SC_UNAUTHORIZED);
             res.setContentType("application/json");
             res.getWriter().write("{\"error\":\"Unauthorized\",\"message\":\""+ ex.getMessage() + "\"}");
      }
}
```

Register in Security Config:

```
http.exceptionHandling()
    .authenticationEntryPoint(customAuthEntryPoint);
```

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Customizing Access Denied Response

Use `AuthenticationEntryPoint` for REST APIs

```
@Component
public class CustomAccessDeniedHandler implements AccessDeniedHandler {
      @Override
      public void handle(HttpServletRequest req, HttpServletResponse res,
                         AccessDeniedException ex) throws IOException {
            res.setStatus(HttpServletResponse.SC_FORBIDDEN);
            res.setContentType("application/json");
            res.getWriter().write("{\"error\":\"Forbidden\",\"message\":\""+ ex.getMessage() + "\"}");
       }
}
```

Register in Security Config:

```
http.exceptionHandling()
      .accessDeniedHandler(customAccessDeniedHandler)
```

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is strictly prohibited.
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Handling Exceptions with @ExceptionHandler

Purpose:

- Catch authentication or authorization exceptions in your controller
- Return **custom JSON responses** without relying solely on Spring Security defaults

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Exercise #7: Handling Exceptions with Spring Security

Objective

- Implement custom exception handlers to return **JSON responses** for authentication and authorization failures.
- Secure endpoints using method-level or URL-based authorization
- Use custom **AuthenticationEntryPoint**, custom **AccessDeniedHandler** and **Controller-level exception handling**

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is strictly prohibited.
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Spring Security Best Practices

- Password Encoding - Use `BCryptPasswordEncoder`
- Password Handling - always store passwords securely
- Consistent Exception Handling (Ensure all exceptions return **consistent JSON responses** for APIs)
- Access Control & Least Privilege
  - Apply **role-based access control** (`ROLE_USER`, `ROLE_ADMIN`) consistently
  - Use **method-level security** for fine-grained control (`@PreAuthorize`)
  - Principle of least privilege:
    - Give users only the permissions they need
    - Avoid “catch-all” roles like `ROLE_SUPERUSER` unless absolutely necessary

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is
THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.

Confidentia
l

Module 9: Final Group Project

Objective:

- Apply Spring Security concepts to the previously-made Library System.
- Implement **role-based access control**, exception handling, and best practices.

Roles:

1. **ROLE_ADMIN** → Manage books (add, edit, delete)
2. **ROLE_USER** → Borrow and return books

Focus Areas:

- Authentication (database or in-memory users)
- Authorization (URL- and method-level security)
- Security Context (fetch current user info)
- Exception handling (401/403 JSON responses)
- Best practices (password hashing, session management)

This document contains confidential data. It is intended solely for the use of authorized recipient(s). Unauthorized use, disclosure, or reproduction is strictly prohibited.

THIS DOCUMENT IS THE PROPERTY OF BANK OF THE PHILIPPINE ISLANDS. STRICTLY CONFIDENTIAL.